GLOBAL SIGMA v3.1 - Annex G

Immutability Implementation Patterns Guide

Technical patterns for forensic-proof certification (Tier 3/4)

---

1. Why Immutability?

For **Certification** (not Technical Conformity), systems must provide **non-repudiable evidence** that logs and design artifacts cannot be altered without detection.

Requirement	Technical Conformity	Certification (T3/T4)
Traceability	✅ Required	✅ Required
Immutability	❌ Optional	✅ **MANDATORY**

Veto D11: If operational logs can be modified without forensic trail → **Irremediable Veto**

---

2. Functional Objectives (DIR)

The Design Immutability Requirement (DIR) establishes:

Objective	Description
Tamper-Evidence 🔍	Alteration/deletion/injection attempts detectable by independent auditor
Sequential Integrity 📋	Chronological order preserved and verifiable; prevents backdating
Data Persistence 💾	Evidence accessible and unalterable for certification validity period

---

3. Acceptable Technologies

Any architecture is acceptable if it meets the functional objectives:

Technology	Description
Cryptographic hashing + timestamp authorities 🔐	Hash stored with third-party timestamp
Blockchain-based registries ⛓️	Distributed ledger with consensus
Notarized digital signatures ✍️	Legally notarized evidence
Hardware Security Modules (HSMs) 🛡️	Tamper-detecting hardware
Institutional multi-party custody 🏛️	Multiple sealed copies with legal witnesses
Append-only databases 📀	WORM (Write Once Read Many) configurations

---

4. Implementation Patterns

Pattern 1: Cryptographic Custody

```
[Organization]
      |
```

```
        ▼
    [Generate Logs]
        │
        ▼
    [Compute Hash] ──────► [Third-party Timestamp Authority]
        │                                   │
        ▼                                   ▼
    [Store Logs Locally]                [Store Timestamp Receipt]
```

Description: Organization retains logs locally but sends hashes to a third-party for timestamping.

Best for: Organizations wanting control + external verification

Example Implementation:

```
# Pseudo-code example
log_entry = "2026-03-03T10:30:00Z | Decision ID: 12345 | Output: 0.87"
hash_value = sha256(log_entry)
timestamp_receipt = timestamp_authority.sign(hash_value)
# Store receipt separately from logs
```

Pattern 2: Distributed Consensus (Blockchain)

```
    [System Events]
          │
          ▼
    [Blockchain / Distributed Ledger]
    ┌──────────────────────────────────┐
    │ Block 1 │ Block 2 │ Block 3 │ ... │
    │ (Hash)──►(Hash)──►(Hash)──►      │
    └──────────────────────────────────┘
          │
          ▼
    [Immutable, Sequentially Ordered Record]
```

Description: Each event becomes a transaction recorded on a blockchain or distributed ledger with multiple validating nodes.

Best for: Multi-stakeholder systems, public accountability

Pattern 3: Hardware-Based (HSM/TPM)

```
    [System Logs]
          │
          ▼
    [HSM / TPM - Hardware Security Module]
```

```
┌──────────────────────────────────┐
│ Private Key (never exits)        │
│ Tamper-detecting enclosure        │
│ Cryptographic signing             │
└──────────────────────────────────┘
      │
      ▼
[Signed Evidence Output]
```

Description: Hardware security module signs logs using private key that never leaves the secure hardware.

Best for: High-security environments, air-gapped systems

Pattern 4: Institutional Multi-Party Custody

```
[Original Sealed Design]
           │
    ┌──────┴──────┐
    ▼             ▼
[Copy A]        [Copy B]        [Copy C]
(Legal Firm)    (Regulator)     (Auditor)
    │              │               │
    └──────────────┴───────────────┘
           │
           ▼
[Verification: All copies match]
```

Description: Multiple independent institutions hold sealed copies; any alteration requires collusion.

Best for: Regulatory frameworks, legal evidence requirements

---

5. Evidence Hierarchy for Certification

Level	Type	Examples	Required For
L1 🟢	**Immutable Forensic Logs**	Cryptographically hashed logs, blockchain records, WORM storage	P5 Continuous Auditability (T3/T4)
L2 🟡	**Technical Artifacts**	Architecture diagrams, data lineage maps, API documentation	All principles (supporting evidence)
L3 🔴	**Declarative Evidence**	Policy documents, self-signed affidavits	Never sufficient alone for T3/T4

---

6. Technology Comparison Matrix

Technology	Tamper-Evidence	Sequential Integrity	Data Persistence	Cost	Complexity
Hashing + Timestamp	⭐⭐⭐	⭐⭐	⭐⭐⭐	Bajo	Medio
Blockchain	⭐⭐⭐	⭐⭐⭐	⭐⭐⭐	Alto	Alto
HSM	⭐⭐⭐	⭐⭐	⭐⭐	Medio	Medio
Multi-party Custody	⭐⭐	⭐⭐	⭐⭐⭐	Medio	Bajo
Append-only DB	⭐⭐	⭐⭐	⭐⭐	Bajo	Bajo

7. Implementation Checklist for T3/T4 Certification

- ☐ **Design Artifacts** preserved immutably (architecture, specifications)
- ☐ **Compliance Evidence** hashed and timestamped (test results, validation records)
- ☐ **Audit Logs** with sequential integrity (no backdating possible)
- ☐ **System State Transitions** recorded (version changes, updates)
- ☐ **Recovery Mechanism** verified (can restore from immutable records)
- ☐ **Independent Verification** possible (third-party can validate immutability)

8. Common Pitfalls to Avoid

❌ **Storing hashes with logs** (attacker can modify both and re-hash)

❌ **Using only organizational databases** (single point of failure/control)

❌ **Proprietary formats** (prevents independent verification)

❌ **Inconsistent timestamp sources** (enables backdating attacks)

❌ **No recovery testing** (immutability without recoverability is useless)

9. Verification Procedure for Auditors

1. **Request** all immutable evidence and custody receipts
2. **Verify** cryptographic continuity (recompute hashes, check timestamps)
3. **Test** tamper-evidence (attempt to modify and detect)
4. **Validate** sequential integrity (check chronological ordering)
5. **Confirm** persistence (evidence available for entire certification period)

10. Relationship to Other Principles

Principle	Immutability Connection
P2 - Reproducible Determinism	Version IDs must be immutably recorded

Principle	Immutability Connection
P5 - Continuous Auditability	Requires Level 1 evidence (immutable logs)
P8 - Multi-Level Governance	Escalation logs require forensic proof
P11 - Fairness	Bias metrics anchored to immutable records
P12 - Security	Vulnerability assessments recorded immutably

Based on GLOBAL SIGMA PUBLIC STANDARD v3.1 - Research Validation Edition (2026-2027) - Author: Dr. Paula Melissa Alfaro Montero - License: CC BY-SA 4.0 - Repository: github.com/lunalfaro/global-sigma-standard-